Security Review: stoquify-referral-release-20260809

Scope

Revision-bound security review of referral release candidate 5d7c73d557e5ca49560fa8627ce45fb75a68de8a..7e46f40589390d837afd61bce26adf551a7e8cea.

- Scan mode: branch_diff
- Target kind: git_diff
- Target ID: target_sha256_ada7e776a8a99a0a731cc3c6952bcfde469c15b91bcf3187e4be66e3dc0b9349
- Revision range: 5d7c73d557e5ca49560fa8627ce45fb75a68de8a...7e46f40589390d837afd61bce26adf551a7e8cea
- Snapshot digest: codex-security-snapshot/v1:sha256:1d74df0bc5da366ec7aad16a4841552de3d91d1cb5319d4e849096130ccb54eb
- Inventory strategy: diff
- Included paths: .
- Excluded paths: none
- Runtime or test status: Exact HEAD production build passed. All 54 changed focused test files passed: 750/750 tests.
- Artifacts reviewed: artifacts/01_context/threat_model.md, artifacts/02_discovery/work_ledger.jsonl, artifacts/02_discovery/finding_discovery_report.md, artifacts/05_findings/validation_summary.md, artifacts/05_findings/attack_path_analysis_report.md, artifacts/04_reconciliation/dedupe_report.md, artifacts/04_reconciliation/deduped_candidates.jsonl
- Scan context: All 183 diff rows received full-file receipts. 48 raw candidates were validated, 38 reportable/deferred candidates received one attack-path pass, and surviving findings were deduplicated to 15.

Limitations and exclusions:

- Production deployment, providers, PostgreSQL target, secrets, Accounting entitlement, migration approval, and real cohort were unavailable.
- Ingress normalization, URL logging, and audit/export/backup ACLs remain unverified external facts.

Scan Summary

Field	Value
Reportable findings	15
Severity mix	medium: 4, low: 11
Confidence mix	high: 15
Coverage	partial

Field	Value
Validation mode	Full-file diff discovery, centralized static/focused-runtime validation, one attack-path pass, and root-cause deduplication.

Canonical artifacts: `scan-manifest.json`, `findings.json`, and `coverage.json`. This report is a deterministic projection of those files.

Threat Model

Multi-tenant Next.js/Prisma financial SaaS diff adding public referral and statement boundaries, protected Accounting workflows, delivery workers, migrations, and pilot/release gates.

Assets

- Tenant isolation and module entitlements
- Authentication and cross-tenant account privacy
- Financial statements and tax identifiers
- Referral analytics
- Consent, audit, close, and release evidence
- Invitation and statement bearers
- Delivery and release-gate integrity

Trust Boundaries

- Internet clients to public routes
- Sessions to protected server actions
- Tenant logic to Prisma persistence
- Outbox workers to external providers
- Repository/operator evidence to CI and release gates

Attacker Capabilities

- Unauthenticated remote requests
- Possession or theft of a bearer
- Authenticated tenant users
- Malicious or compromised tenant administrator
- Contributor or manifest author where explicitly analyzed

Security Objectives

- Preserve tenant isolation, RBAC, and entitlements
- Protect bearer secrets, statements, and tax identifiers
- Keep business and release evidence authentic
- Bound workloads
- Make certification prove one verified workflow

Assumptions

- Target is immutable SHA 7e46f40589390d837afd61bce26adf551a7e8cea.
- Unavailable production facts are deferred rather than guessed.
- Developer-only gate edits without privilege delta are not application vulnerabilities.

Findings

Finding	Severity	Confidence	Detailed write-up
Public statement action parses unbounded input before token authentication	medium	high	inline below
Public referral click fingerprinting permits analytics poisoning	medium	high	inline below
Public statement redaction leaves organization and customer tax identifiers in bearer responses	medium	high	inline below
One recipient token can create unbounded distinct statement actions	medium	high	inline below
Accountant invitation reveals cross-tenant account existence and activation state	low	high	inline below
Accountant invitation action bypasses enforced Accounting module entitlement	low	high	inline below
Accountant invite delivery trusts a caller-asserted consent digest	low	high	inline below
Accountant invitation bearer is copied into redirect URLs	low	high	inline below
Authorized referral funnel reads perform an unbounded all-time event query	low	high	inline below
Pilot gate can combine evidence from different recipient journeys	low	high	inline below
Caller-asserted statement consent is propagated as verified evidence	low	high	inline below
Missing-evidence acceptance can resolve findings without Accounting module entitlement enforcement	low	high	inline below
Missing-evidence response action omits Accounting module entitlement enforcement	low	high	inline below
Pilot readiness trusts unauthenticated approval and consent attestations	low	high	inline below
Unthrottled statement reads append durable evidence on every request	low	high	inline below

Confidence Scale

Label	Meaning
high	Direct evidence supports the finding with no material unresolved blocker.
medium	Evidence supports a plausible issue, but material runtime or reachability proof remains.
low	Evidence is incomplete and the item is retained only for explicit follow-up.

[1] Public statement action parses unbounded input before token authentication

Field	Value
Severity	medium
Confidence	high
Confidence rationale	request.json() and required-text normalization occur before the statement bearer reaches token verification.
Category	uncontrolled-resource-consumption
CWE	CWE-400
Affected lines	app/api/customer-statements/[statementId]/actions/route.ts:39-44, app/api/customer-statements/[statementId]/actions/route.ts:49-63

Summary

An unauthenticated caller can submit an arbitrarily large JSON body and large strings that are parsed and normalized before recipient-token authentication, creating pre-authentication CPU and memory pressure.

Validation

request.json() and required-text normalization occur before the statement bearer reaches token verification. Validation details were not recorded separately.

Dataflow

The canonical finding records the affected path at app/api/customer-statements/[statementId]/actions/route.ts:39-44, app/api/customer-statements/[statementId]/actions/route.ts:49-63, but no expanded source-to-sink narrative was recorded.

Reachability

Reachability was not recorded beyond the canonical finding summary and affected locations.

Severity

Medium — The scan assigned medium severity; no separate canonical severity rationale was recorded.

Additional runtime or deployment evidence could raise or lower this severity.

Remediation

Enforce Content-Length and body-size limits, cap every string before decimal or hash work, authenticate the token before processing the payload, and add over-limit regression tests.

[2] Public referral click fingerprinting permits analytics poisoning

Field	Value
Severity	medium
Confidence	high

Field	Value
Confidence rationale	The public route accepts proxy-derived IP and caller-supplied User-Agent; the pair becomes the daily uniqueness key and a new event is inserted whenever it changes.
Category	improper-control-of-interaction-frequency
CWE	CWE-799
Affected lines	app/api/referrals/[referralCode]/route.ts:8-12, app/api/referrals/[referralCode]/route.ts:22-26, services/referrals/referral-attribution.service.ts:92-124

Summary

An unauthenticated visitor can rotate User-Agent and, when ingress permits, apparent IP to inflate durable referral-click events and tenant funnel metrics.

Validation

The public route accepts proxy-derived IP and caller-supplied User-Agent; the pair becomes the daily uniqueness key and a new event is inserted whenever it changes. Validation details were not recorded separately.

Dataflow

The canonical finding records the affected path at app/api/referrals/[referralCode]/route.ts:8-12, app/api/referrals/[referralCode]/route.ts:22-26, services/referrals/referral-attribution.service.ts:92-124, but no expanded source-to-sink narrative was recorded.

Reachability

Reachability was not recorded beyond the canonical finding summary and affected locations.

Severity

Medium — The scan assigned medium severity; no separate canonical severity rationale was recorded.

Additional runtime or deployment evidence could raise or lower this severity.

Remediation

Use ingress-verified client identity, server-controlled per-code/global rate limits, and a dedupe key that is not caller-selectable; test header and User-Agent rotation.

[3] Public statement redaction leaves organization and customer tax identifiers in bearer responses

Field	Value
Severity	medium
Confidence	high
Confidence rationale	The statement payload includes organization.taxIdentifier and customer.taxId while the recursive external-redaction denylist removes neither key.
Category	exposure-of-sensitive-information

Field	Value
CWE	CWE-200
Affected lines	services/accounting/customer-statement.service.ts:550-566, services/accounting/customer-statement-access.service.ts:26-37, services/accounting/customer-statement-access.service.ts:163-175

Summary

A valid statement bearer receives organization and customer tax identifiers, expanding the consequence of token disclosure beyond the intended public redaction boundary.

Validation

The statement payload includes organization.taxIdentifier and customer.taxId while the recursive external-redaction denylist removes neither key. Validation details were not recorded separately.

Dataflow

The canonical finding records the affected path at services/accounting/customer-statement.service.ts:550-566, services/accounting/customer-statement-access.service.ts:26-37, services/accounting/customer-statement-access.service.ts:163-175, but no expanded source-to-sink narrative was recorded.

Reachability

Reachability was not recorded beyond the canonical finding summary and affected locations.

Severity

Medium — The scan assigned medium severity; no separate canonical severity rationale was recorded.

Additional runtime or deployment evidence could raise or lower this severity.

Remediation

Use an explicit public-payload allowlist or remove taxIdentifier and taxId during serialization; add a test that rejects unapproved and newly introduced keys by default.

[4] One recipient token can create unbounded distinct statement actions

Field	Value
Severity	medium
Confidence	high
Confidence rationale	Deduplication uses only caller-chosen idempotencyKey or correlationId values; each distinct request creates durable action, event, state, and access evidence.
Category	allocation-without-limits
CWE	CWE-770
Affected lines	services/accounting/customer-statement-recipient-action.service.ts:277-300, services/accounting/customer-statement-recipient-action.service.ts:342-370

Summary

A valid action-capable bearer can vary caller-controlled keys to create unlimited disputes or promises to pay for one statement.

Validation

Deduplication uses only caller-chosen idempotencyKey or correlationId values; each distinct request creates durable action, event, state, and access evidence. Validation details were not recorded separately.

Dataflow

The canonical finding records the affected path at services/accounting/customer-statement-recipient-action.service.ts:277-300, services/accounting/customer-statement-recipient-action.service.ts:342-370, but no expanded source-to-sink narrative was recorded.

Reachability

Reachability was not recorded beyond the canonical finding summary and affected locations.

Severity

Medium — The scan assigned medium severity; no separate canonical severity rationale was recorded.

Additional runtime or deployment evidence could raise or lower this severity.

Remediation

Add server-side semantic uniqueness, per-token/per-statement quotas, duplicate-open-action rejection independent of caller keys, and a distributed rate limit.

[5] Accountant invitation reveals cross-tenant account existence and activation state

Field	Value
Severity	low
Confidence	high
Confidence rationale	A global email lookup branches into distinguishable GRANTED, inactive-error, and INVITED outcomes.
Category	observable-discrepancy
CWE	CWE-203
Affected lines	services/accounting/accountant-client-invite.service.ts:481-519

Summary

A fresh-authenticated administrator can probe arbitrary emails and distinguish active, inactive, and nonexistent Stoquify accounts across tenants.

Validation

A global email lookup branches into distinguishable GRANTED, inactive-error, and INVITED outcomes. Validation details were not recorded separately.

Dataflow

The canonical finding records the affected path at services/accounting/accountant-client-invite.service.ts:481-519, but no expanded source-to-sink narrative was recorded.

Reachability

Reachability was not recorded beyond the canonical finding summary and affected locations.

Severity

Low — The scan assigned low severity; no separate canonical severity rationale was recorded.

Additional runtime or deployment evidence could raise or lower this severity.

Remediation

Return a uniform outward result, avoid exposing internal identifiers, and test indistinguishable responses for all account states.

[6] Accountant invitation action bypasses enforced Accounting module entitlement

Field	Value
Severity	low
Confidence	high
Confidence rationale	The action declares permission, audit resource, and fresh authentication but omits the Accounting module enforcement option used by neighboring actions.
Category	missing-authorization
CWE	CWE-862
Affected lines	actions/accounting/accountant-access.actions.ts:68-83, services/accounting/accountant-client-invite.service.ts:482-519

Summary

A tenant administrator with the invite permission can invoke accountant invitation or grant behavior when the tenant is not entitled to the Accounting module.

Validation

The action declares permission, audit resource, and fresh authentication but omits the Accounting module enforcement option used by neighboring actions. Validation details were not recorded separately.

Dataflow

The canonical finding records the affected path at actions/accounting/accountant-access.actions.ts:68-83, services/accounting/accountant-client-invite.service.ts:482-519, but no expanded source-to-sink narrative was recorded.

Reachability

Reachability was not recorded beyond the canonical finding summary and affected locations.

Severity

Low — The scan assigned low severity; no separate canonical severity rationale was recorded.

Additional runtime or deployment evidence could raise or lower this severity.

Remediation

Add the enforced Accounting module option and tests for disabled, suspended, and unentitled tenants.

[7] Accountant invite delivery trusts a caller-asserted consent digest

Field	Value
Severity	low
Confidence	high
Confidence rationale	The worker checks only sha256 syntax and equality with the persisted payload; no independent consent record is resolved.
Category	insufficient-verification-of-data-authenticity
CWE	CWE-345
Affected lines	services/communication/accountant-client-invite-worker.service.ts:33-45, services/communication/accountant-client-invite-worker.service.ts:327-340

Summary

An authorized inviter can supply a self-authored consent digest that becomes durable invitation evidence and passes delivery validation.

Validation

The worker checks only sha256 syntax and equality with the persisted payload; no independent consent record is resolved. Validation details were not recorded separately.

Dataflow

The canonical finding records the affected path at services/communication/accountant-client-invite-worker.service.ts:33-45, services/communication/accountant-client-invite-worker.service.ts:327-340, but no expanded source-to-sink narrative was recorded.

Reachability

Reachability was not recorded beyond the canonical finding summary and affected locations.

Severity

Low — The scan assigned low severity; no separate canonical severity rationale was recorded.

Additional runtime or deployment evidence could raise or lower this severity.

Remediation

Reference a server-issued immutable consent record bound to organization, destination, purpose, actor, and policy version; verify it before delivery.

[8] Accountant invitation bearer is copied into redirect URLs

Field	Value
Severity	low
Confidence	high
Confidence rationale	The route reads invite from the inbound query, the service copies it into registrationPath, and the route emits it in Location.
Category	sensitive-information-in-query-string
CWE	CWE-598
Affected lines	app/api/referrals/[referralCode]/route.ts:21-29, services/referrals/referral-attribution.service.ts:40-50, services/referrals/referral-attribution.service.ts:126-134

Summary

A valid invitation bearer is propagated into a second URL, increasing exposure through histories, request-target logs, telemetry, and copied links.

Validation

The route reads invite from the inbound query, the service copies it into registrationPath, and the route emits it in Location. Validation details were not recorded separately.

Dataflow

The canonical finding records the affected path at app/api/referrals/[referralCode]/route.ts:21-29, services/referrals/referral-attribution.service.ts:40-50, services/referrals/referral-attribution.service.ts:126-134, but no expanded source-to-sink narrative was recorded.

Reachability

Reachability was not recorded beyond the canonical finding summary and affected locations.

Severity

Low — The scan assigned low severity; no separate canonical severity rationale was recorded.

Additional runtime or deployment evidence could raise or lower this severity.

Remediation

Exchange the bearer once for a short-lived server-side session or secure HttpOnly cookie, then redirect to a token-free canonical URL and scrub URL logs/history.

[9] Authorized referral funnel reads perform an unbounded all-time event query

Field	Value
Severity	low

Field	Value
Confidence	high
Confidence rationale	findMany has no date range, pagination, aggregation, or take limit and nests events for every attribution.
Category	uncontrolled-resource-consumption
CWE	CWE-400
Affected lines	services/referrals/referral-funnel-read-model.service.ts:46-72

Summary

An authorized request loads all historical referral attributions and associated events into application memory, with cost growing indefinitely.

Validation

findMany has no date range, pagination, aggregation, or take limit and nests events for every attribution. Validation details were not recorded separately.

Dataflow

The canonical finding records the affected path at services/referrals/referral-funnel-read-model.service.ts:46-72, but no expanded source-to-sink narrative was recorded.

Reachability

Reachability was not recorded beyond the canonical finding summary and affected locations.

Severity

Low — The scan assigned low severity; no separate canonical severity rationale was recorded.

Additional runtime or deployment evidence could raise or lower this severity.

Remediation

Compute bounded database aggregates, require a time window, add pagination or hard caps, and load-test realistic high-volume history.

[10] Pilot gate can combine evidence from different recipient journeys

Field	Value
Severity	low
Confidence	high
Confidence rationale	The query joins workflow stages mainly by chronological ordering rather than a shared token, delivery, recipient, and conversion identity.
Category	insufficient-verification-of-data-authenticity
CWE	CWE-345
Affected lines	scripts/customer-referral-pilot-evidence-gate.js:200-216, scripts/customer-referral-pilot-evidence-gate.js:274

Summary

The gate can mark sequence_complete when different recipients supply different stages, so it does not prove one end-to-end journey.

Validation

The query joins workflow stages mainly by chronological ordering rather than a shared token, delivery, recipient, and conversion identity. Validation details were not recorded separately.

Dataflow

The canonical finding records the affected path at scripts/customer-referral-pilot-evidence-gate.js:200-216, scripts/customer-referral-pilot-evidence-gate.js:274, but no expanded source-to-sink narrative was recorded.

Reachability

Reachability was not recorded beyond the canonical finding summary and affected locations.

Severity

Low — The scan assigned low severity; no separate canonical severity rationale was recorded.

Additional runtime or deployment evidence could raise or lower this severity.

Remediation

Join every stage through one statement token, delivery, recipient/action identity, referral attribution, and converted target user; add mixed-journey negative tests.

[11] Caller-asserted statement consent is propagated as verified evidence

Field	Value
Severity	low
Confidence	high
Confidence rationale	The browser constructs the digest, the service checks only its syntax, and the worker verifies equality with the same caller-originated value.
Category	insufficient-verification-of-data-authenticity
CWE	CWE-345
Affected lines	components/customers/CustomerStatementWorkflow.tsx:159-168, services/accounting/customer-statement-delivery.service.ts:215-236, services/communication/customer-statement-delivery-worker.service.ts:436-450

Summary

An authorized sender can submit any well-formed consent digest and have it recorded as explicit consent without a trusted consent record.

Validation

The browser constructs the digest, the service checks only its syntax, and the worker verifies equality with the same caller-originated value. Validation details were not recorded separately.

Dataflow

The canonical finding records the affected path at components/customers/CustomerStatementWorkflow.tsx:159-168, services/accounting/customer-statement-delivery.service.ts:215-236, services/communication/customer-statement-delivery-worker.service.ts:436-450, but no expanded source-to-sink narrative was recorded.

Reachability

Reachability was not recorded beyond the canonical finding summary and affected locations.

Severity

Low — The scan assigned low severity; no separate canonical severity rationale was recorded.

Additional runtime or deployment evidence could raise or lower this severity.

Remediation

Create a server-issued immutable consent record bound to actor, subject, purpose, policy version, timestamp, and nonce; require worker verification.

[12] Missing-evidence acceptance can resolve findings without Accounting module entitlement enforcement

Field	Value
Severity	low
Confidence	high
Confidence rationale	The action enforces reviewer permission, audit, and fresh authentication but omits the Accounting module guard.
Category	missing-authorization
CWE	CWE-862
Affected lines	actions/accounting/close-assurance.actions.ts:187-215

Summary

A reviewer can accept evidence and resolve a close-assurance finding even when Accounting is not entitled or active.

Validation

The action enforces reviewer permission, audit, and fresh authentication but omits the Accounting module guard. Validation details were not recorded separately.

Dataflow

The canonical finding records the affected path at actions/accounting/close-assurance.actions.ts:187-215, but no expanded source-to-sink narrative was recorded.

Reachability

Reachability was not recorded beyond the canonical finding summary and affected locations.

Severity

Low — The scan assigned low severity; no separate canonical severity rationale was recorded.

Additional runtime or deployment evidence could raise or lower this severity.

Remediation

Add the enforced Accounting module guard and test that unentitled tenants produce no acceptance, finding, audit, or revalidation side effect.

[13] Missing-evidence response action omits Accounting module entitlement enforcement

Field	Value
Severity	low
Confidence	high
Confidence rationale	The protected action checks permission and audit settings but supplies no Accounting module gate.
Category	missing-authorization
CWE	CWE-862
Affected lines	actions/accounting/close-assurance.actions.ts:166-184

Summary

A user retaining the close-finding comment permission can move missing evidence into review without an enforced Accounting entitlement check.

Validation

The protected action checks permission and audit settings but supplies no Accounting module gate. Validation details were not recorded separately.

Dataflow

The canonical finding records the affected path at actions/accounting/close-assurance.actions.ts:166-184, but no expanded source-to-sink narrative was recorded.

Reachability

Reachability was not recorded beyond the canonical finding summary and affected locations.

Severity

Low — The scan assigned low severity; no separate canonical severity rationale was recorded.

Additional runtime or deployment evidence could raise or lower this severity.

Remediation

Add the enforced Accounting module guard and prove no response or audit side effect occurs for an unentitled tenant.

[14] Pilot readiness trusts unauthenticated approval and consent attestations

Field	Value
Severity	low
Confidence	high
Confidence rationale	The gate checks approvedBy only for string shape and required attestations only for literal true, then records approval without authentication or signature.
Category	insufficient-verification-of-data-authenticity
CWE	CWE-345
Affected lines	scripts/customer-referral-pilot-evidence-gate.js:388-415, scripts/customer-referral-pilot-evidence-gate.js:532-535

Summary

A pilot-manifest author can self-assert approver identity, production execution, tenant consent, and data hygiene as release evidence.

Validation

The gate checks approvedBy only for string shape and required attestations only for literal true, then records approval without authentication or signature. Validation details were not recorded separately.

Dataflow

The canonical finding records the affected path at scripts/customer-referral-pilot-evidence-gate.js:388-415, scripts/customer-referral-pilot-evidence-gate.js:532-535, but no expanded source-to-sink narrative was recorded.

Reachability

Reachability was not recorded beyond the canonical finding summary and affected locations.

Severity

Low — The scan assigned low severity; no separate canonical severity rationale was recorded.

Additional runtime or deployment evidence could raise or lower this severity.

Remediation

Require signed or authenticated maker-checker attestations tied to immutable evidence and tenant consent; reject self-authored placeholders in tests.

[15] Unthrottled statement reads append durable evidence on every request

Field	Value
Severity	low
Confidence	high

Field	Value
Confidence rationale	Every granted access increments a counter and inserts an access-log row, with no coalescing or rate limit in the reviewed path.
Category	uncontrolled-resource-consumption
CWE	CWE-400
Affected lines	services/accounting/customer-statement-access.service.ts:392-413

Summary

A valid bearer can repeatedly read one statement and force a database update plus immutable log insertion on each request.

Validation

Every granted access increments a counter and inserts an access-log row, with no coalescing or rate limit in the reviewed path. Validation details were not recorded separately.

Dataflow

The canonical finding records the affected path at services/accounting/customer-statement-access.service.ts:392-413, but no expanded source-to-sink narrative was recorded.

Reachability

Reachability was not recorded beyond the canonical finding summary and affected locations.

Severity

Low — The scan assigned low severity; no separate canonical severity rationale was recorded.

Additional runtime or deployment evidence could raise or lower this severity.

Remediation

Apply per-token rate limits, coalesce repeat reads into bounded time buckets, and test high-frequency access for bounded growth.

Reviewed Surfaces

Surface	Risk Area	Outcome	Notes
Changed-file diff inventory	coverage	No issue found	183/183 worklist rows have full-file receipts; no row was dropped.
Authentication, RBAC, tenant, and module boundaries	authorization	Reported	Four low findings remain; hypothesized Better Auth high paths were suppressed after focused validation.
Public statement and referral APIs	public-boundary	Reported	Four medium and several low resource, integrity, bearer, and disclosure findings were retained.
Financial statement and close-assurance workflows	financial-workflow	Reported	Entitlement, public-payload redaction, consent provenance, and bounded-write issues were assessed.
Provider and worker delivery paths	delivery	Reported	Statement and accountant-invite consent evidence remains caller-asserted.

Surface	Risk Area	Outcome	Notes
Pilot and release assurance gates	release-assurance	Reported	Cross-journey stitching and unsigned attestations remain low; the developer-only comment bypass did not survive policy.
Generated architecture graphs and test fixtures	non-production	No issue found	Reviewed as changed supporting artifacts; no runtime vulnerability survived.
Production ingress, URL logging, and canonical-origin behavior	deployment-boundary	Needs follow-up	External facts are required for query-bearer, forwarded-header, and request-origin candidates.
Production storage, audit/export ACLs, providers, and pilot cohort	operational-boundary	Needs follow-up	Unavailable operational facts are preserved as proof gaps.

Open Questions And Follow Up

- Does production canonicalize Host and forwarding headers and redact full request targets from every CDN, proxy, application, APM, support, and browser-history sink?
- Will password-reset tokens use cryptographic generation and digest-only storage before the restored path is production-reachable?
- Which lower-privileged roles, exports, backups, or analytics systems can read tax identifiers or enumerable metadata digests?
- Recipient-action query-bearer exposure depends on production request-target retention and reader access.
    - Follow-up prompt: Review deferred unit RCAND-007 and close its stated proof gap.
- Forwarded-IP audit integrity depends on production proxy stripping and trusted client-address injection.
    - Follow-up prompt: Review deferred unit RCAND-010 and close its stated proof gap.
- Private statement query-bearer exposure depends on downstream log/history retention.
    - Follow-up prompt: Review deferred unit RCAND-011 and close its stated proof gap.
- Statement-view audit attribution depends on the production forwarded-header trust boundary.
    - Follow-up prompt: Review deferred unit RCAND-013 and close its stated proof gap.
- Attacker-controlled redirect origin requires a production proxy/Host configuration that accepts hostile origin metadata.
    - Follow-up prompt: Review deferred unit RCAND-014 and close its stated proof gap.
- GET statement bearer replay depends on production URL retention or disclosure.
    - Follow-up prompt: Review deferred unit RCAND-017 and close its stated proof gap.
- POST action bearer exposure depends on production request-target logging and client behavior.
    - Follow-up prompt: Review deferred unit RCAND-018 and close its stated proof gap.
- Math.random generation and plaintext reset-token storage are confirmed, but no prediction oracle or lower-privileged active-token reader was established.
    - Follow-up prompt: Review deferred unit RCAND-023 and close its stated proof gap.
- Tax identifiers appear in audit details; confidentiality impact depends on audit/export/support ACLs and retention.
    - Follow-up prompt: Review deferred unit RCAND-024 and close its stated proof gap.

- Enumerable metadata hashes are confirmed, but no lower-privileged digest-store reader was established.
    - Follow-up prompt: Review deferred unit RCAND-025 and close its stated proof gap.
- Long-lived statement bearers are in URLs; production request-target exposure is an external fact.
    - Follow-up prompt: Review deferred unit RCAND-037 and close its stated proof gap.